



Database Security & Authorization

Mr. S.K.Patil

Database Security & Authorization

Introduction to Database Security Issues –

- Database **security** is a broad area that **addresses many issues**, including the following:
 - Various legal and ethical issues regarding the right to access certain information
 - Policy issues at the governmental, institutional, or corporate level as to what kinds of information should not be made publicly available
 - System-related issues such as the system levels at which various security functions should be enforced
 - The need in some organizations to identify multiple security levels and to categorize the data and users based on these classifications

Database Security & Authorization

Introduction to Database Security Issues –

➤ Threats to Databases:

- Threats to databases can result in the loss or degradation of some or all of the following commonly accepted security goals: integrity, availability, and confidentiality.
- **Loss of integrity** - Database integrity refers to the requirement that information be protected from improper modification. Integrity is lost if unauthorized changes are made to the data by either intentional or accidental acts. If the loss of system or data integrity is not corrected, it could result in inaccuracy, fraud, or erroneous decisions.
- **Loss of availability** - Database availability refers to making objects available to a human user or a program to which they have a legitimate right.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Threats to Databases:

- **Loss of confidentiality** - Database confidentiality refers to the protection of data from unauthorized disclosure. Unauthorized, unanticipated, or unintentional disclosure could result in loss of public confidence, embarrassment, or legal action against the organization.
- To protect databases against these types of threats, it is common to implement four kinds of control measures: access control, inference control, flow control, and encryption.
- In a multiuser database system, the DBMS must provide techniques to enable certain users or user groups to access selected portions of a database without gaining access to the rest of the database.
- This is particularly important when a large integrated database is to be used by many different users within the same organization.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Threats to Databases:

- For example, sensitive information such as employee salaries or performance reviews should be kept confidential from most of the database system's users.
- A DBMS typically includes a database security and authorization subsystem that is responsible for ensuring the security of portions of a database against unauthorized access.

Database Security & Authorization

Introduction to Database Security Issues –

➤ **Control Measures :**

- Four main control measures are used to provide security of data in databases:
 - Access control
 - Inference control
 - Flow control
 - Data encryption

➤ **Access Control -**

- A security problem common to computer systems is that preventing unauthorized user from accessing the system itself, either to obtain information or to make malicious changes in a portion of the database.
- The security mechanism of a DBMS must include provisions for restricting access to the database system. This function, called access control.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Control Measures :

➤ Access Control -

- The access control is handled by creating user accounts and passwords to control the login process by the DBMS.

➤ Inference Control –

- Statistical databases are used to provide statistical information or summaries of values based on various criteria.
- For example, a database for population statistics may provide statistics based on age groups, income levels, household size, education levels, and other criteria.
- Statistical database users are allowed to access the database to retrieve statistical information about a population but not to access the detailed confidential information about specific individuals.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Control Measures :

➤ Inference Control –

- Security for statistical databases must ensure that information about individuals cannot be accessed.
- It is sometimes possible to deduce or infer certain facts concerning individuals from queries that involve only summary statistics on groups; consequently, this must not be permitted either. This problem, called statistical database security.
- The corresponding control measures are called inference control measures.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Control Measures :

➤ Flow Control –

- It prevents information from flowing in such a way that it reaches unauthorized users.
- Channels that are pathways for information to flow implicitly in ways that violate the security policy of an organization are called covert channels

➤ Data Encryption –

- It is used to protect sensitive data (such as credit card numbers) that is transmitted via some type of communications network.
- Encryption can be used to provide additional protection for sensitive portions of a database as well.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Control Measures :

➤ Data Encryption –

- The data is encoded using some coding algorithm.
- An unauthorized user who accesses encoded data will have difficulty deciphering it, but authorized users are given decoding or decrypting algorithms (or keys) to decipher the data.
- Encrypting techniques that are very difficult to decode without a key have been developed for military applications.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Sensitive Data and Types of Disclosures :

- Sensitivity of data is a measure of the importance assigned to the data by its owner, for the purpose of denoting its need for protection.
- Some databases contain only sensitive data while other databases may contain no sensitive data at all.
- Handling databases that fall at these two extremes is relatively easy, because these can be covered by access control.
- The situation becomes tricky when some of the data is sensitive while other data is not.
- Several factors can cause data to be classified as sensitive:
 - **Inherently sensitive** - The value of the data itself may be so revealing or confidential that it becomes sensitive. e.g. salary

Database Security & Authorization

Introduction to Database Security Issues –

➤ Sensitive Data and Types of Disclosures :

- Several factors can cause data to be classified as sensitive:
 - **From a sensitive source** - The source of data may indicate a need for secrecy. e.g. an informer whose identity must be kept secret.
 - **Declared sensitive** - The owner of the data may have explicitly declared it as sensitive.
 - **A sensitive attribute or sensitive record** - The particular attribute or record may have been declared sensitive. e.g. salary history record
 - **Sensitive in relation to previously disclosed data** - Some data may not be sensitive by itself but will become sensitive in the presence of some other data. e.g. exact latitude and longitude information for a location where some previously recorded event happened that was later deemed sensitive.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Sensitive Data and Types of Disclosures :

- It is the responsibility of database administrator and security administrator to collectively enforce the security policies of an organization.
- This shows whether access should be permitted to a certain database attribute or not for individual users or for categories of users
- Several factors need to be considered before deciding whether it is safe to reveal the data. The three most important factors are -

➤ Data availability –

- If a user is updating a field, then this field becomes inaccessible and other users should not be able to view this data.
- This blocking is only temporary and only to ensure that no user sees any inaccurate data.
- This is typically handled by the concurrency control mechanism.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Sensitive Data and Types of Disclosures :

- The three most important factors are -
 - **Access acceptability –**
 - Data should only be revealed to authorized users.
 - A database administrator may also deny access to a user request even if the request does not directly access a sensitive data item.
 - The requested data may reveal information about the sensitive data that the user is not authorized to have.
 - **Authenticity assurance –**
 - Before granting access, certain external characteristics about the user may also be considered. e.g. a user may only be permitted access during working hours.

Database Security & Authorization

Introduction to Database Security Issues –

➤ Sensitive Data and Types of Disclosures :

➤ The three most important factors are -

➤ Authenticity assurance –

➤ The system may track previous queries to ensure that a combination of queries does not reveal sensitive data.

Database Security & Authorization

Discretionary Access Control –

- Discretionary Access Control is a mechanism that allows the owner of a resource to control who has access to that resource and what actions they can perform on it.
- The typical method of enforcing discretionary access control in a database system is based on the granting and revoking of privileges.
- DAC is identity-based access control.
- DAC mechanisms will be controlled by user identification such as username and password.
- DAC is discretionary because the owners can transfer objects or any authenticated information to other users. In simple words, the owner can determine the access privileges.

Database Security & Authorization

Discretionary Access Control –

➤ Types of Discretionary Privileges -

- In SQL, an authorization identifier is used to refer to a user account (or group of user accounts).
- The DBMS must provide selective access to each relation in the database based on specific accounts.
- There are two levels for assigning privileges to use the database system:
 - **The account level** - At this level, the DBA specifies the particular privileges that each account holds independently of the relations in the database.
 - **The relation (or table) level** - At this level, the DBA can control the privilege to access each individual relation or view in the database.

Database Security & Authorization

Discretionary Access Control –

➤ Types of Discretionary Privileges -

- The privileges at the account level apply to the capabilities provided to the account itself and can include the CREATE SCHEMA or CREATE TABLE privilege, to create a schema or base relation.
- The CREATE VIEW privilege; the ALTER privilege, to apply schema changes such as adding or removing attributes from relations.
- The DROP privilege, to delete relations or views; the MODIFY privilege, to insert, delete, or update tuples; and the SELECT privilege, to retrieve information from the database by using a SELECT query.
- If a certain account does not have the CREATE TABLE privilege, no relations can be created from that account.
- Account-level privileges are not defined as part of SQL; they are left to the DBMS implementers to define.

Database Security & Authorization

Discretionary Access Control –

➤ Types of Discretionary Privileges -

- The second level of privileges applies to the relation level, whether they are base relations or virtual (view) relations.
- These privileges are defined for SQL.
- Privileges at the relation level specify for each user the individual relations on which each type of command can be applied.
- Some privileges also refer to individual columns (attributes) of relations.
- SQL commands provide privileges at the relation and attribute level only.
- The granting and revoking of privileges generally follow an authorization model for discretionary privileges known as the access matrix model.

Database Security & Authorization

Discretionary Access Control –

➤ Types of Discretionary Privileges -

- To control the granting and revoking of relation privileges, each relation R in a database is assigned an **owner account**, which is typically the account that was used when the relation was created in the first place.
- The owner of a relation is given all privileges on that relation.
- In SQL, the DBA can assign an owner to a whole schema by creating the schema and associating the appropriate authorization identifier with that schema, using the CREATE SCHEMA command.
- The owner account holder can pass privileges on any of the owned relations to other users by granting privileges to their accounts.

Database Security & Authorization

Discretionary Access Control –

➤ Types of Discretionary Privileges -

- In SQL the following types of privileges can be granted on each individual relation R:
 - **SELECT(retrieval or read) privilege on R** - Gives the account retrieval privilege. In SQL this gives the account the privilege to use the SELECT statement to retrieve tuples from R.
 - **Modification privileges on R** - This gives the account the capability to modify the tuples of R. In SQL this includes three privileges: UPDATE, DELETE, and INSERT.
 - **References privilege on R** - This gives the account the capability to reference (or refer to) a relation R when specifying integrity constraints. This privilege can also be restricted to specific attributes of R.

Database Security & Authorization

Discretionary Access Control –

➤ Specifying Privileges through the Use of Views -

- The mechanism of views is an important discretionary authorization mechanism in its own right.
- For example, if the owner A of a relation R wants another account B to be able to retrieve only some fields of R, then A can create a view V of R that includes only those attributes and then grant SELECT on V to B.
- The same applies to limiting B to retrieving only certain tuples of R; a view V' can be created by defining the view by means of a query that selects only those tuples from R that A wants to allow B to access.

Database Security & Authorization

Discretionary Access Control –

➤ Revoking of Privileges -

- In some cases it is desirable to grant a privilege to a user temporarily.
- For example, the owner of a relation may want to grant the SELECT privilege to a user for a specific task and then revoke that privilege once the task is completed.
- Hence, a mechanism for revoking privileges is needed.
- In SQL a REVOKE command is included for the purpose of canceling privileges.

Database Security & Authorization

Discretionary Access Control –

➤ Propagation of Privileges Using the GRANT OPTION -

- Whenever the owner A of a relation R grants a privilege on R to another account B, the privilege can be given to B with or without the GRANT OPTION.
- If the GRANT OPTION is given, this means that B can also grant that privilege on R to other accounts.
- Suppose that B is given the GRANT OPTION by A and that B then grants the privilege on R to a third account C, also with the GRANT OPTION.
- In this way, privileges on R can propagate to other accounts without the knowledge of the owner of R.
- If the owner account A now revokes the privilege granted to B, all the privileges that B propagated based on that privilege should automatically be revoked by the system.

Database Security & Authorization

Discretionary Access Control –

➤ Propagation of Privileges Using the GRANT OPTION -

- It is possible for a user to receive a certain privilege from two or more sources.
- Example - A4 may receive a certain UPDATE R privilege from both A2 and A3. In such a case, if A2 revokes this privilege from A4, A4 will still continue to have the privilege by virtue of having been granted it from A3. If A3 later revokes the privilege from A4, A4 totally loses the privilege.
- Hence, a DBMS that allows propagation of privileges must keep track of how all the privileges were granted so that revoking of privileges can be done correctly and completely.

Database Security & Authorization

Mandatory Access Control –

- Mandatory Access Control is a centralized access control system.
- MAC regulates access to resources based on the clearance levels of users and the attributes of objects they seek to access.
- MAC is known for its high security levels.
- Organizations rely on it to protect sensitive data, limit the risk of cyber attacks, and meet regulatory requirements in fields like finance or healthcare.
- With mandatory controls, users can have different levels of authorization depending on their position and role.
- Admins can assign different sensitivity levels to data or applications, depending on security needs.
- Typical security classes are top secret (TS), secret (S), confidential (C), and unclassified (U), where TS is the highest level and U the lowest.

Database Security & Authorization

Mandatory Access Control –

- Other more complex security classification schemes exist, in which the security classes are organized in a lattice. For simplicity, we will use the system with four security classification levels, where $TS \geq S \geq C \geq U$.
- The commonly used model for multilevel security, known as the Bell-LaPadula model, classifies each **subject** (user, account, program) and **object** (relation, tuple, column, view, operation) into one of the security classifications TS, S, C, or U.
- We will refer to the clearance (classification) of a subject S as $class(S)$ and to the classification of an object O as $class(O)$.
- Two restrictions are enforced on data access based on the subject/object classifications:
 - A subject S is not allowed read access to an object O unless $class(S) \geq class(O)$. This is known as the **simple security property**.

Database Security & Authorization

Mandatory Access Control –

- Two restrictions are enforced on data access based on the subject/object classifications:
 - A subject S is not allowed to write an object O unless $\text{class}(S) \leq \text{class}(O)$. This is known as the **star property** (or *-property).
- The first restriction is intuitive & enforces the obvious rule that no subject can read an object whose security classification is higher than the subject's security clearance.
- The second restriction is less intuitive. It prohibits a subject from writing an object at a lower security classification than the subject's security clearance.
- Violation of this rule would allow information to flow from higher to lower classifications, which violates a basic tenet of multilevel security.

Database Security & Authorization

Mandatory Access Control –

➤ Discretionary Access Control vs. Mandatory Access Control –

Discretionary Access Control	Mandatory Access Control
In DAC, the owner can determine the access and privileges and can restrict the resources based on the identity of the users.	In MAC, the system only determines the access and the resources will be restricted based on the clearance of the subjects.
DAC is easier to implement.	MAC is difficult to implement.
DAC is less secure to use.	MAC is more secure to use.
Users will be provided access based on their identity and not using levels.	Users will be restricted based on their power and level of hierarchy.
DAC has high flexibility with no rules and regulations.	MAC is not flexible as it contains lots of strict rules and regulations.

Database Security & Authorization

Mandatory Access Control –

➤ Discretionary Access Control vs. Mandatory Access Control –

Discretionary Access Control	Mandatory Access Control
DAC has complete trust in users.	MAC has trust only in administrators.
Decisions will be based only on user ID and ownership.	Decisions will be based on objects and tasks, and they can have their own ids.
Information flow is impossible to control.	Information flow can be easily controlled.
DAC can be applied in all domains.	MAC can be applied in the military, government, and intelligence.
DAC is vulnerable to trojan horses	MAC prevents virus flow from a higher level to a lower level.

Database Security & Authorization

Role Based Access Control –

- Role-based access control (RBAC) used for managing and enforcing security in large-scale enterprise-wide systems.
- Its basic notion is that privileges and other permissions are associated with **organizational roles**, rather than individual users.
- Individual users are then assigned to appropriate roles.
- Roles can be created using the CREATE ROLE and DESTROY ROLE commands.
- The GRANT and REVOKE commands can then be used to assign and revoke privileges from roles, as well as for individual users when needed.
- e.g. a company may have roles such as sales account manager, purchasing agent, clerk, department manager
- Multiple individuals can be assigned to each role.

Database Security & Authorization

Role Based Access Control –

- Security privileges that are common to a role are granted to the role name, and any individual assigned to this role would automatically have those privileges granted.
- RBAC can be used with traditional discretionary and mandatory access controls; it ensures that only authorized users in their specified roles are given access to certain data or resources.
- The **role hierarchy** in RBAC is a natural way to organize roles to reflect the organization's lines of authority and responsibility.
- By convention, junior roles at the bottom are connected to progressively senior roles as one moves up the hierarchy.
- RBAC models have several desirable features, such as flexibility, policy neutrality, better support for security management and for developing secure Web-based applications.

Database Security & Authorization

Role Based Access Control –

- RBAC models include the capabilities available in traditional DAC and MAC policies.
- An RBAC model provides mechanisms for addressing the security issues related to the execution of tasks and workflows, and for specifying user defined and organization-specific policies.
- Easier deployment over the Internet has been another reason for the success of RBAC models.

Database Security & Authorization

SQL Injection –

- SQL Injection is one of the most common threats to a database system.
- **SQL injection is a technique attackers use to modify or retrieve data from databases.**
- Some of the attacks on databases that are quite frequent are:
 - **Unauthorized privilege escalation** - This attack is characterized by an individual attempting to elevate his or her privilege by attacking vulnerable points in the database systems.
 - **Privilege abuse** - This attack is performed by a privileged user. e.g. an administrator who is allowed to change student information can use this privilege to update student grades without the instructor's permission.
 - **Denial of service** - A Denial of Service (DOS) attack is an attempt to make resources unavailable to its intended users. It is a general attack category in which access to network applications or data is denied to intended users by overflowing the buffer or consuming resources.

Database Security & Authorization

SQL Injection –

- Some of the other attacks on databases that are quite frequent are:
 - **Weak Authentication** - If the user authentication scheme is weak, an attacker can impersonate the identity of a legitimate user by obtaining their login credentials.
- **SQL Injection Methods –**
 - Web programs and applications that access a database can send commands and data to the database, as well as display data retrieved from the database through the Web browser.
 - In an SQL Injection attack, the attacker injects a string input through the application, which changes or manipulates the SQL statement to the attacker's advantage.

Database Security & Authorization

SQL Injection –

➤ SQL Injection Methods –

- An SQL Injection attack can harm the database in various ways, such as unauthorized manipulation of the database, or retrieval of sensitive data.
- It can also be used to execute system level commands that may cause the system to deny service to the application.

➤ Types of Injection attacks –

➤ SQL Manipulation –

- A manipulation attack, which is the most common type of injection attack, changes an SQL command in the application.
- Example - by adding conditions to the WHERE-clause of a query, or by expanding a query with additional query components using set operations.
- A typical manipulation attack occurs during database login.

Database Security & Authorization

SQL Injection –

➤ SQL Injection Methods –

➤ Types of Injection attacks –

➤ SQL Manipulation –

- Example - suppose a simplistic authentication procedure issues the following query and checks to see if any rows were returned:

SELECT * FROM users WHERE username = 'jake'and PASSWORD = 'jakespasswd'

The attacker can try to change (or manipulate) the SQL statement, by changing it as follows:

SELECT * FROM users WHERE username = 'jake'and (PASSWORD = 'jakespasswd'or 'x'= 'x')

As a result, attacker who knows that 'jake' is a valid login of some user is able to log into the database system as 'jake' without knowing his password & is able to do everything that 'jake' may be authorized to do to the database system.

Database Security & Authorization

SQL Injection –

➤ SQL Injection Methods –

➤ Types of Injection attacks –

➤ Code Injection –

- This type of attack attempts to add additional SQL statements or commands to the existing SQL statement by exploiting a computer bug, which is caused by processing invalid data.
- The attacker can inject or introduce code into a computer program to change the course of execution.
- Code injection is a popular technique for system hacking or cracking to gain information.

Database Security & Authorization

SQL Injection –

➤ SQL Injection Methods –

➤ Types of Injection attacks –

➤ Function Call Injection –

- In this kind of attack, a database function or operating system function call is inserted into a vulnerable SQL statement to manipulate the data or make a privileged system call.
- For example, it is possible to exploit a function that performs some aspect related to network communication.
- In addition, functions that are contained in a customized database package, or any custom database function, can be executed as part of an SQL query.
- In particular, dynamically created SQL queries can be exploited since they are constructed at run time.

Database Security & Authorization

SQL Injection –

➤ Risks Associated with SQL Injection -

- SQL injection is harmful and the risks associated with it provide motivation for attackers.
- Some of the risks associated with SQL injection attacks are –
 - **Database Fingerprinting** - The attacker can determine the type of database being used in the backend so that he can use database-specific attacks that correspond to weaknesses in a particular DBMS.
 - **Denial of Service** - The attacker can flood the server with requests, thus denying service to valid users, or they can delete some data.
 - **Bypassing Authentication** - This is one of the most common risks, in which the attacker can gain access to the database as an authorized user and perform all the desired tasks.

Database Security & Authorization

SQL Injection –

➤ Risks Associated with SQL Injection -

- Some of the risks associated with SQL injection attacks are –
 - **Identifying Injectable Parameters** - In this type of attack, the attacker gathers important information about the type and structure of the back-end database of a Web application. This attack is made possible by the fact that the default error page returned by application servers is often overly descriptive.
 - **Executing Remote Commands** - This provides attackers with a tool to execute arbitrary commands on the database. For example, a remote user can execute stored database procedures and functions from a remote SQL interactive interface.
 - **Performing Privilege Escalation** - This type of attack takes advantage of logical flaws within the database to upgrade the access level.

Database Security & Authorization

SQL Injection –

➤ Protection Techniques against SQL Injection -

- Protection against SQL injection attacks can be achieved by applying certain programming rules to all Web-accessible procedures and functions.

➤ Bind Variables (Using Parameterized Statements) –

- The use of bind variables (also known as parameters) protects against injection attacks and also improves performance.
- Consider the following example using Java and JDBC:

```
PreparedStatement stmt = conn.prepareStatement("SELECT * FROM  
EMPLOYEE WHERE EMPLOYEE_ID=? AND PASSWORD=?");
```

```
stmt.setString(1,employee_id);
```

```
stmt.setString(2,password);
```

Database Security & Authorization

SQL Injection –

➤ Protection Techniques against SQL Injection -

➤ Bind Variables (Using Parameterized Statements) –

- Instead of embedding the user input into the statement, the input should be bound to a parameter.
- In this example, the input '1' is assigned (bound) to a bind variable 'employee_id' and input '2' to the bind variable 'password' instead of directly passing string parameters.

➤ Filtering Input (Input Validation) –

- This technique can be used to remove escape characters from input strings by using the SQL Replace function.
- For example, the delimiter single quote (') can be replaced by two single quotes ('').

Database Security & Authorization

SQL Injection –

➤ Protection Techniques against SQL Injection -

➤ Filtering Input (Input Validation) –

- Some SQL Manipulation attacks can be prevented by using this technique, since escape characters can be used to inject manipulation attacks.
- However, because there can be a large number of escape characters, this technique is not reliable.

➤ Function Security –

- Database functions, both standard and custom, should be restricted, as they can be exploited in the SQL function injection attacks.